Recon Target Based Strategies

Educational Bug Bounty Series • Authorized Security Research Only

■ Reconnaissance Strategies — Target-Based Scope

Contributed by Cyber_Spy.404 | Bug Bounty Notes

Authorization rule: *The program's written scope always overrides a general reconnaissance checklist. Do not scan related companies, IP ranges, or subdomains unless they are explicitly in scope.*

■ Executive Summary

The source HTML, *Recon Target Based.html*, organizes reconnaissance into **small**, **medium**, and **large** scope. It scales the breadth of discovery according to the scope definition, from a single URL to organization-wide assets. The source lists directory enumeration, technology fingerprinting, ports, parameters, historical URLs, JavaScript review, cloud storage, dorking, and vulnerability checks.

■ Core Testing Methodology

1. Small Scope Reconnaissance

Source definition: Specific URLs only, often staging/development/testing or a single URL.

- [ ] Directory enumeration
- [ ] Technology fingerprinting
- [ ] Port scanning, only where permitted
- [ ] Parameter fuzzing, within program limits
- [ ] Wayback/history review
- [ ] Known-vulnerability review
- [ ] Hardcoded information in JavaScript
- [ ] Domain-specific GitHub and Google search
- [ ] Broken-link hijacking assessment
- [ ] Data-breach exposure review without using leaked credentials
- [ ] Misconfigured cloud-storage review

2. Medium Scope Reconnaissance

Source definition: Usually wildcard scope where all subdomains are included.

- [ ] Subdomain enumeration
- [ ] Subdomain takeover checks
- [ ] Probing and technology fingerprinting
- [ ] Port scanning within scope
- [ ] Known-vulnerability review
- [ ] Template-based scanning (the source names Nuclei/“Jeales”)
- [ ] Misconfigured cloud-storage review
- [ ] Broken-link hijacking assessment
- [ ] Directory enumeration
- [ ] JavaScript review

- [ ] GitHub reconnaissance
- [ ] Google dorking
- [ ] Data-breach exposure review
- [ ] Parameter fuzzing
- [ ] Internet search engines (the source names Shodan, Censys, Spyse)
- [ ] IP-range enumeration only if explicitly in scope
- [ ] Wayback/history review
- [ ] Pattern extraction with GF for categories such as XSS/SSRF, followed by safe manual validation
- [ ] Heartbleed exposure review where applicable and authorized
- [ ] General security-misconfiguration review

3. Large Scope Reconnaissance

Source definition: Organization-related assets, including child companies, subdomains, or labelled assets, are considered in scope **only when the program explicitly says so**.

- [ ] Track application signatures and crawl authorized targets
- [ ] Subsidiary/acquisition enumeration, bounded by written scope
- [ ] Reverse lookup
- [ ] ASN and IP-space enumeration and service identification, only for authorized ranges
- [ ] Subdomain enumeration and takeover checks
- [ ] Probing and technology fingerprinting
- [ ] Port scanning
- [ ] Known-vulnerability review
- [ ] Template-based scanning
- [ ] Cloud-storage and broken-link-hijacking checks
- [ ] Directory enumeration and JavaScript review
- [ ] GitHub and Google reconnaissance
- [ ] Data-breach exposure review without credential use
- [ ] Parameter fuzzing
- [ ] Search-engine discovery (Shodan/Censys/other sources)
- [ ] IP-range enumeration only when included in scope
- [ ] Wayback/history review
- [ ] Pattern extraction for relevant vulnerability classes
- [ ] Heartbleed and general security-misconfiguration review
- [ ] Consider other network/web reconnaissance vectors only when authorized

■ High-Value Tips & Edge Cases

- A wildcard domain does **not** automatically include the organization's IP ranges, subsidiaries, third-party SaaS, or cloud tenants.
- Passive discovery is not the same as permission for active scanning.
- A scanner finding is a lead, not a confirmed vulnerability.
- Check scope exclusions, request limits, safe-harbor terms, and rules for automated tools before testing.
- Broken-link hijacking, subdomain takeover, and cloud-storage issues can affect real users; use non-invasive verification and stop before claiming or taking over a resource.

- Data-breach sources may contain credentials or personal data. Do not log in, reuse secrets, or download unrelated private information.

■■ Educational Checklist & Safe Examples

```
Program: [Program Name]
Asset: [Exact In-Scope Asset]
Scope type: [Single URL / Wildcard / Organization-defined]
Active scanning permitted: [Yes / No / Limited]
Rate limit: [Program-defined]
Recon source: [Passive / Active]
Observation: [Non-sensitive summary]
Status: [Lead / Confirmed / Not Reproduced]
Evidence: [Redacted]
```

- [ ] Written scope saved and reviewed
- [ ] Exclusions and rate limits noted
- [ ] Assets verified against the program scope
- [ ] Passive and active steps distinguished
- [ ] Findings manually validated
- [ ] Sensitive information not accessed or copied
- [ ] Report contains minimal, redacted evidence

■■ Mitigation & Remediation

For defenders, maintain an authoritative asset inventory, remove abandoned DNS/service records, restrict exposed services, protect cloud storage, avoid secrets in client-side code, patch exposed services, and continuously monitor assets. Define clear scope and safe-testing rules for bounty programs.

■ Source Notes

Based on *Recon Target Based.html*. The source defines three scope levels and lists the reconnaissance activities under each. This guide preserves those categories while clarifying that organization-related assets and active tests require explicit program authorization. The source's spelling “Jeales” is retained in the checklist note; the HTML does not define that tool.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.